

Enterprise DevSecOps Final Project Plan (Finance Industry)

End-to-End CI/CD + Security + IaC + Monitoring Platform

Training Batch Final Capstone Project

Project Goal

Design and implement a production-grade DevSecOps platform for a financial services application using Infrastructure as Code, Secure CI/CD, Kubernetes, Cloud Security, Compliance Controls, Observability, Governance, and GitOps principles.

Business Objective:

Build a secure, scalable, highly available cloud-native banking/payment application platform capable of meeting financial industry expectations for security, auditability, resiliency, compliance, and automation.

Recommended Technology Stack

Cloud: AWS

Source Control: GitHub

CI/CD: GitHub Actions + ArgoCD

Containers: Docker

Kubernetes: Amazon EKS [Fargate]

IaC: Terraform

Configuration Management: Ansible

Secrets: Github Secrets + AWS Secrets Manager

Image Registry: Amazon ECR

Security: Checkov, tfsec, Trivy, Gype, SonarQube, OWASP ZAP, Falco, Kyverno

Monitoring: Prometheus, Grafana, AlertManager

Logging: Fluent Bit, OpenSearch, Kibana [ELK]

Tracing: OpenTelemetry, Jaeger

Compliance: CIS Benchmarks, NIST, PCI-DSS, SOC2

Incident Management: PagerDuty/ServiceNow

Repository Structure

/terraform

/ansible

/app

/helm

/gitops

/security

/monitoring

/runbooks

/docs

`/.github/workflows`

Project Phases

Phase 1 – Architecture & Design
Phase 2 – Cloud Foundation & Landing Zone
Phase 3 – Terraform Infrastructure Deployment
Phase 4 – Kubernetes Platform Engineering
Phase 5 – Security Controls Implementation
Phase 6 – CI/CD Pipeline Development
Phase 7 – GitOps Deployment Strategy
Phase 8 – Observability & Monitoring
Phase 9 – Compliance & Governance
Phase 10 – Disaster Recovery & Resilience
Phase 11 – Documentation & Knowledge Transfer

Detailed Security Requirements

SAST: SonarQube
SCA: Dependency scanning
Secrets Scanning: GitLeaks
IaC Scanning: Checkov and tfsec
Container Scanning: Trivy
DAST: OWASP ZAP
Runtime Security: Falco
Admission Control: Kyverno
RBAC: Least Privilege
Encryption: TLS 1.3, KMS
Secrets Rotation
Audit Logging
PCI-DSS aligned controls

CI/CD Pipeline Stages

1. Code Commit
2. PR Validation
3. Unit Testing
4. SAST Scan
5. Dependency Scan
6. Secret Detection
7. Terraform Validation

8. Checkov Scan
9. Container Build
10. Container Scan
11. Push to ECR
12. Deploy to Dev
13. Integration Testing
14. DAST Scan
15. Approval Gate
16. Deploy to Stage
17. Performance Testing
18. Production Approval
19. Production Deployment
20. Post Deployment Validation
21. Rollback Automation

Monitoring & Observability

Golden Signals:

Latency

Traffic

Errors

Saturation

Infrastructure Monitoring

Kubernetes Monitoring

Application Monitoring

Business Transaction Monitoring

Synthetic Monitoring

Distributed Tracing

Centralized Logging

Executive Dashboards

Security Dashboards

Deliverables

Architecture Diagram

Terraform Modules

Ansible Playbooks

GitHub Actions Pipelines

ArgoCD GitOps Setup

Security Controls

Monitoring Dashboards

Runbooks
Operational Documentation
Disaster Recovery Procedures
Cost Optimization Report
Final Demonstration